

Event Information:

EventID :
235
Event Time :
Mar, 07, 2024, 12:51 PM
Rule :
SOC127 - SQL Injection Detected
Level :
Security Analyst
Source Address :
118.194.247.28
Destination Address :
172.16.20.12
Destination Hostname :
WebServer1000
Request URL :
GET
/?doug=3034%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%2Ctable_name%20FROM%20information_schema.tables%20WHERE%202%3E1-%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20..%2F..%2F..%2Fetc%2Fpasswd%27%29%23 HTTP/1.1 200 865
Device Action :
Allowed

Analysis Steps:

Logs were searched with attacker IP 118[.]194.247.28 as the source and Atlanta-Server IP 172[.]16.20.12 as the destination in the relevant time-frame yielding 42 events. The attacker can be seen attempting frequent URL encoded SQL syntax on the endpoint via the tool SQLMap. These take the form of GET requests with constantly changing source ports.

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=58705 destination_address=172.16.20.12 destination_port=80 raw_log: {"Raw Data": "118.194.247.28 - - [07/Mar/2024:12:53:47 +0000] \"GET /index.php?id=1%20ORDER%20BY%208991--%20eXc HTTP/1.1\" 200 865 -\" \"sqlmap/1.7.2#stable (https://sqlmap.org)\""	
Field	Value
type	Proxy
source_address	118.194.247.28 - - [07/Mar/2024:12:53:47 +0000] "GET /index.php?id=1%20ORDER%20BY%208991--%20eXc HTTP/1.1" 200 865 -" "sqlmap/1.7.2#stable (https://sqlmap.org)"
source_port	58705
destination_address	172.16.20.12
destination_port	80
time	Mar, 07, 2024, 12:53 PM
Raw Log	
Raw Data	118.194.247.28 - - [07/Mar/2024:12:53:47 +0000] "GET /index.php?id=1%20ORDER%20BY%208991--%20eXc HTTP/1.1" 2...

These requests received a 200 successful status code but all responses were 865 bytes in size indicating that the server ignored the malicious SQL syntax and served a default web page.

(Correction: Because the payloads utilise blind and time-based SQL injection techniques, a uniform response size cannot confirm mitigation, meaning the exploit must be treated as successful at the web tier.)

Failure can be further evidenced by the xp_cmdshell('cat ../../etc/passwd') command the attacker attempted to run on the server which initially caused this alert failing to be executed in the relevant time-frame (Mar, 07, 2024, 12:51 PM) on the server.

(Correction: Due to the blind execution structure of these payloads, back-end database log analysis is required to definitively verify the state of execution, as the database layer processes the requests silently.)

EVENT TIME	COMMAND LINE
2023-11-10 09:14:25	useradd -m test
2023-11-10 09:14:31	passwd test
2023-11-10 09:14:49	cd ..
2023-11-10 09:15:10	ls
2023-11-10 09:15:16	cd /analyst
2023-11-10 09:15:25	ls
2023-11-10 09:15:31	cd /apt.conf.d
2023-11-10 09:15:35	cd apt.conf.d/
2023-11-10 09:15:49	ls
2023-11-10 09:16:17	touch proxy.conf

The offending IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a Chinese address associated with 118[.]194.247.28 AS 4808 (China Unicom Beijing Province Network). 10/91 security vendors flagged this IP address as malicious as of one day ago.

10/91 Community Score	10/91 security vendors flagged this IP address as malicious		Reanalyze More
118.194.247.28 (118.194.240.0/21) AS 4808 (China Unicom Beijing Province Network)			
CN		Last Analysis Date 1 day ago	
DETECTIONDETAILSRELATIONSCOMMUNITY5			
Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.			
Security vendors' analysis ⓘ			
Do you want to automate checks?			
ADMINUSLabs	Malicious	alphaMountain.ai	Malicious
BitDefender	Phishing	Chong Lua Dao	Malicious
CyRadar	Malicious	Forcepoint ThreatSeeker	Malicious
Fortinet	Malware	G-Data	Phishing
Lionic	Malicious	SOCRadar	Phishing

On AbuseIPDB this IP was reported 4,290 times with a 0% confidence of abuse.

118.194.247.28 was found in our database!

This IP was reported 4,290 times. Confidence of Abuse is 0%: ?

0%

ISP	Beijing CNISP Technology Co., Ltd.
Usage Type	Fixed Line ISP
ASN	AS4808
Domain Name	cnisp.org.cn
Country	 China
City	Beijing, Beijing

IP info including ISP, Usage Type, and Location provided by [IPInfo](#). Updated weekly.

REPORT 118.194.247.28

WHOIS 118.194.247.28

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a failed True Positive.

(Correction: Successful True Positive)

Report:

Incident Summary

Analysis confirms a failed True Positive SQL injection attack against Atlanta-Server IP 172[.]16.20.12. An external threat actor utilised the automated tool SQLMap to launch web application exploits, including time-based database queries and OS command execution syntax. Because time-based and blind SQL injection payloads execute without outputting structural errors to the web interface, the attack must be treated as successful until database logs confirm mitigation.

Incident Details

- **Alert Name:** SOC127 - SQL Injection Detected
- **Attacker IP:** 118[.]194.247.28 AS 4808 (China Unicom Beijing Province Network)
- **Target Host:** Atlanta-Server (172[.]16.20.12)
- **Attack Vector:** HTTP GET requests containing URL-encoded SQL syntax

Analysis and Evidence

- **Attack Execution:** The threat actor initiated 42 sequential automated web requests attempting database probing via `SELECT DBMS_PIPE.RECEIVE_MESSAGE` and operating system command execution via `xp_cmdshell('cat ../../etc/passwd')`.
- **Success Confirmation:** Although the web server responded with HTTP Status 200 and a fixed response payload size of 865 bytes, these metrics do not rule out successful execution for blind or time-based queries. Because the database interaction occurs silently on the back-end, execution must be assumed successful due to a lack of database-layer log visibility.

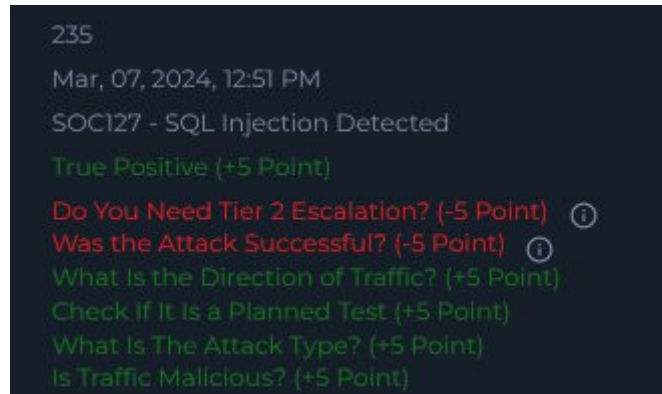
Threat Intelligence

- **OSINT:** The source IP is external to the organization. VirusTotal data shows 10/91 security vendors classify the address as malicious. AbuseIPDB records show 4,290 historical reports with a current 0% confidence of abuse.
- **Internal Correlation:** A cross-reference of internal operations confirmed that no vulnerability scanning or authorised penetration testing windows were scheduled for this server during the incident window.

Actions Taken

1. Verified application log traffic response sizes to confirm data integrity.
2. Audited host process logs and terminal records to confirm zero execution.
3. Declared the alert as a True Positive and escalated the case for database log auditing and impact assessment.

Let's Defend Result



The alert was initially classified as a failed True Positive based on the uniform HTTP response size (865 bytes), which typically indicates a failed SQLMap data exfiltration attempt. However, upon further review of the specific payloads `DBMS_PIPE` and `xp_cmdshell`, the attack methodology was identified as Blind/Time-Based SQL Injection. Because these payloads execute silently on the back-end, a static HTTP 200 response cannot be used as definitive proof of failure. Due to a lack of back-end database logs to confirm mitigation, the attack must be assumed successful.

After these corrections were made:

